



中华人民共和国国家标准

GB/T 40861—2021

汽车信息安全通用技术要求

General technical requirements for vehicle cybersecurity

2021-10-11 发布

2022-05-01 实施

国家市场监督管理总局 发布
国家标准化管理委员会

目 次

前言 III

引言 IV

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 保护对象 3

 5.1 概述 3

 5.2 车内系统 3

 5.3 车外通信 3

6 技术要求 4

 6.1 原则性要求 4

 6.2 系统性防御策略要求 4

 6.3 保护维度要求 5

附录 A（资料性） 信息安全威胁 9

参考文献 13

前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中华人民共和国工业和信息化部提出。

本文件由全国汽车标准化技术委员会(SAC/TC 114)归口。

本文件起草单位：浙江吉利控股集团有限公司、华为技术有限公司、中国汽车技术研究中心有限公司、北京奇虎科技有限公司、戴姆勒大中华区投资有限公司、标致雪铁龙(中国)汽车贸易有限公司上海分公司、泛亚汽车技术中心有限公司、广州汽车集团股份有限公司、工业和信息化部计算机与微电子发展研究中心、宝马(中国)服务有限公司、大众汽车(中国)投资有限公司、东软集团股份有限公司、大陆投资(中国)有限公司、北京梆梆安全科技有限公司、中国信息通信研究院、东风汽车集团股份有限公司技术中心、中国第一汽车股份有限公司。

本文件主要起草人：尹杨、张旭武、张行、张容波、潘凯、吴含冰、张屹、吕明、冯志敏、冯海涛、张金池、郭盈、王喆、赵闻、陈静相、杨文昌、卢佐华、孙娅苹、李燕、高长胜。

引言

随着智能化和网联化技术快速发展和应用,汽车从相对孤立的电子机械系统逐渐演变成能与外界进行信息交互的智能系统,汽车网联化衍生的信息安全问题随之而来。

与通信等行业的信息安全主要造成财产损失不同,作为高速行驶的载人和载物的交通工具,当发生汽车信息安全问题,不仅会造成财产损失,还将严重威胁人身和公共安全。

本文件基于汽车信息安全风险危害及诱因,针对保护对象制定通用技术要求(汽车整车及其电子电气系统和组件的技术要求可根据功能设计和风险评估结果而定),与其他管理要求标准配合使用,指导建立汽车信息安全技术体系。标准框架如图 1 所示,在规定原则性要求、系统性防御策略要求等基础技术要求的同时,从以下八个维度针对子保护对象制定具体技术要求:

- a) 真实性;
- b) 保密性;
- c) 完整性;
- d) 可用性;
- e) 访问可控性;
- f) 抗抵赖;
- g) 可核查性;
- h) 可预防性。

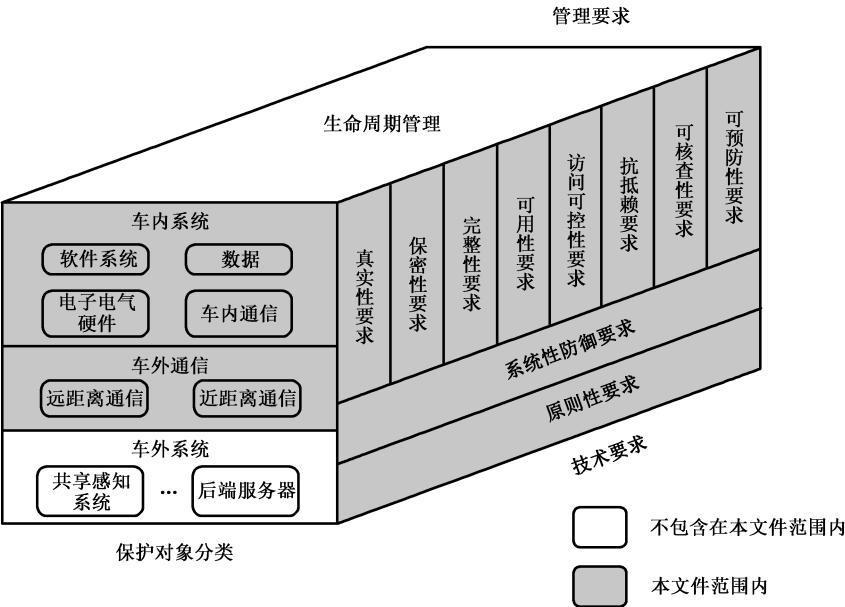


图 1 标准框架

汽车信息安全通用技术要求

1 范围

本文件规定了汽车信息安全的保护对象和技术要求。
本文件适用于 M 类、N 类汽车整车及其电子电气系统和组件。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中,注日期的引用文件,仅该日期对应的版本适用于本文件;不注日期的引用文件,其最新版本(包括所有的修改单)适用于本文件。

GB/T 29246—2017 信息技术 安全技术 信息安全管理体系 概述和词汇
GB/T 34590.3—2017 道路车辆 功能安全 第 3 部分:概念阶段

3 术语和定义

GB/T 29246—2017 界定的以及下列术语和定义适用于本文件。

3.1

汽车信息安全 vehicle cybersecurity

汽车的电子电气系统、组件和功能被保护,使其资产不受威胁的状态。

3.2

真实性 authenticity

一个实体是其所声称实体的特性。

[来源:GB/T 29246—2017,2.8,有修改]

3.3

保密性 confidentiality

信息对未授权的个人、实体或过程不可用或不泄露的特性。

[来源:GB/T 29246—2017,2.12]

3.4

完整性 integrity

准确和完备的特性。

[来源:GB/T 29246—2017,2.40]

3.5

可用性 availability

根据授权实体的要求可访问和可使用的特性。

[来源:GB/T 29246—2017,2.9]

3.6

访问可控性 access controllability

确保对资产的访问是基于业务和安全要求进行授权和限制的特性。

3.7

抗抵赖 non-repudiation

证明所声称事态或行为的发生及其源头的的能力。

[来源:GB/T 29246—2017,2.54]

3.8

可核查性 accountability

确保可从一个实体的行为唯一地追溯到该实体的特性。

3.9

可预防性 preventability

对信息异常行为和攻击行为进行识别、侦测以及相应安全响应的能力。

3.10

拒绝服务 denial of service; DoS

因阻止对系统资源的授权访问或延迟系统运行和功能实现而导致授权用户的可用性受损。

3.11

分布式拒绝服务攻击 distributed denial of service; DDoS

通过损害或控制多个系统对攻击目标系统的带宽和资源进行泛洪攻击而实现拒绝服务。

3.12

后门 backdoor

能够绕过系统认证等安全机制的管控而进入信息系统的通道。

3.13

安全重要参数 security important parameter

与安全相关的信息,包含秘密密钥和私钥、口令之类的鉴别数据或其他密码相关参数的信息。

3.14

访问控制 access control

确保对资产的访问是基于业务和安全要求进行授权和限制的手段。

[来源:GB/T 29246—2017,2.1]

4 缩略语

下列缩略语适用于本文件。

CAN: 控制器局域网络(Controller Area Network)

DoS: 拒绝服务(Denial of Service)

DDoS: 分布式拒绝服务攻击(Distributed Denial of Service)

ECU: 电子控制单元(Electronic Control Unit)

FTP: 文件传输协议(File Transfer Protocol)

HSM: 硬件安全模块(Hardware Secure Module)

ICCID: 集成电路卡识别码(Integrate Circuit Card Identity)

IMSI: 国际移动用户识别码(International Mobile Subscriber Identity)

JTAG: 联合测试工作组(Joint Test Action Group)

LIN: 局域互连网络(Local Interconnect Network)

OBD: 车载诊断(On-Board Diagnostics)

TCM: 可信密码模块(Trusted Cryptography Module)

TEE: 可信执行环境(Trusted Execution Environments)

- Telnet： 电信网络协议(Telecommunication Network Protocol)
- TFTP： 简单文件传输协议(Trivial File Transfer Protocol)
- TLS： 传输层安全协议(Transport Layer Security)
- TPM： 可信平台模块(Trusted Platform Module)
- V2X： 车辆与车外其他设备之间的无线通信(Vehicle to Everything)
- Wi-Fi： 无线保真(Wireless Fidelity)

5 保护对象

5.1 概述

按照保护对象范畴,汽车可划分为三类子保护对象:车内系统、车外通信和车外系统,如图 2 所示。

- 注 1: 本文件不涉及车外系统。
- 注 2: 为了更好地理解保护对象在不同维度的技术要求,在附录 A 的 A.1 和 A.2 中分别列举了车内系统和车外通信所面临的典型的安全威胁。

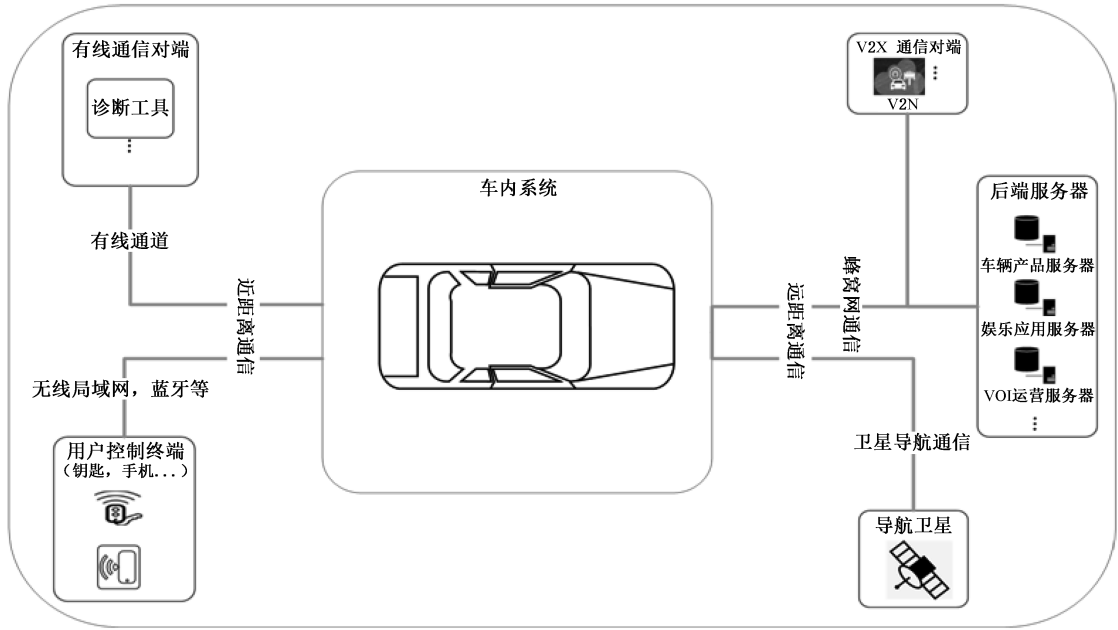


图 2 保护对象模型

5.2 车内系统

车内系统分为如下子保护对象：

- a) 软件系统；
- b) 电子电气硬件；
- c) 车内数据；
- d) 车内通信。

注：车内通信即车内系统、组件之间的通信，例如 CAN 通信、LIN 通信、以太网通信等。

5.3 车外通信

车外通信分为如下子保护对象：

- a) 车外远距离通信；
- b) 车外近距离通信。

注 1：车外通信是指整车与车外终端的通信。

注 2：车外远距离通信是指蜂窝移动通信、卫星导航等。

注 3：车外近距离通信是指蓝牙、近场无线通信和 Wi-Fi 等。

6 技术要求

6.1 原则性要求

6.1.1 业务适用性原则

产品的信息安全设计应结合业务或功能环境的实际需求，同时考虑对业务或功能的正常使用的影响。

6.1.2 软件无后门原则

软件系统不应留有后门。

6.1.3 功能最小化原则

无用的软件组件、协议端口和 ECU 硬件调试接口应禁用或移除；器件的管脚信息不宜暴露。

6.1.4 最小化授权原则

产品的访问和信息处理活动应只授予必要的权限。

6.1.5 权限分离原则

重要保护对象的信息处理活动应具备两个或两个以上的权限，且各权限应相互分离和单独授予。

6.1.6 默认设置原则

产品应完成默认的信息安全设置；该设置对用户的信息安全设置诉求应做到最小化和最简单化。

6.2 系统性防御策略要求

6.2.1 总则

产品可采用下列系统性防御策略的一种：

- a) 纵深防御；
- b) 主动防御；
- c) 韧性防御。

注：系统性防御策略，是基于构建系统的整体信息安全防护而采取的整体防御策略，以避免因各个信息安全防护措施相互孤立而造成整体防护能力不足的问题。

6.2.2 纵深防御要求

纵深防御符合以下要求：

- a) 根据保护对象所处的环境条件和信息安全管理的要求，应由外到里对保护对象实施层层设防的防护措施；
- b) 各层次的安全措施应相互依托，形成系统化的防护机制，从而提高系统的整体抗攻击能力。

6.2.3 主动防御要求

主动防御应采用包括但不限于情报分享、入侵检测技术、信息安全策略动态调整和各信息安全模块之间协同等措施,以降低信息系统在遭受网络攻击时所面临的风险。

6.2.4 韧性防御要求

信息安全设计应综合考虑可靠性、功能安全等多个方面的工程设计,以提高系统的生存能力和自愈能力。

6.3 保护维度要求

6.3.1 车内系统的保护要求

6.3.1.1 软件系统的保护要求

6.3.1.1.1 真实性

软件系统应符合以下真实性要求:

- a) 当升级、加载和安装时,验证提供方的身份真实性和来源的合法性;
- b) 验证登录用户身份的真实性和合法性。

6.3.1.1.2 保密性

软件系统应支持防被逆向分析,宜采用代码混淆或加壳等措施。

6.3.1.1.3 完整性

当软件系统在启动、升级、加载和安装时,应验证其完整性。

6.3.1.1.4 可用性

当软件系统设计符合 GB/T 34590.3—2017 中 ASIL C 和 D 级时,其应支持防 DoS/DDoS 攻击。

6.3.1.1.5 访问可控性

软件系统应符合以下访问可控性要求:

- a) 具备访问权限控制的管理机制;
- b) 验证对各软件系统资源和数据资产的访问、操作和使用的权限;
- c) 验证软件系统的升级、加载和安装的权限。

6.3.1.1.6 抗抵赖

软件系统应具备在请求的情况下为数据原发者或接收者提供数据原发证据和数据接收证据的功能。

示例:采用数字签名技术等。

6.3.1.1.7 可核查性

软件系统应符合以下可核查性要求:

- a) 记录重要信息安全事件,包括但不限于用户活动和操作指令;记录内容宜包含事件的时间、用户、事件类型、事件处置结果等信息;

- b) 保护审计日志不被非法篡改、删除和伪造。

6.3.1.1.8 可预防性

软件系统应具备对自身受到信息安全攻击的感知能力,当检测到信息安全攻击时,宜进行日志记录、信息安全告警或攻击阻止的响应。

6.3.1.2 电子电气硬件保护要求

6.3.1.2.1 完整性

对 ECU 的封装(外壳、封条等)应采用完整性保护。

示例:使用揭开时能留迹象的封条。

6.3.1.2.2 访问可控性

电子电气硬件应移除或者禁止不必要的调试接口。

注:为了更好地理解保护对象在不同维度的技术要求,在 A.1.2 中列举了车内硬件所面临的典型安全威胁。

6.3.1.3 车内数据保护要求

6.3.1.3.1 保密性

安全重要参数应符合如下保密性要求:

- a) 不以明文方式传输;
- b) 存储在安全的环境中。

示例:存储在 TPM、TCM、HSM 或 TEE 等安全环境中。

6.3.1.3.2 完整性

安全重要参数应支持完整性校验。

6.3.1.3.3 可用性

安全重要参数应防止丢失和被误删除,宜采用备份或专用安全空间存储等措施。

6.3.1.4 车内通信的保护要求

6.3.1.4.1 真实性

车内通信应验证通信双方身份的真实性。

6.3.1.4.2 保密性

车内通信应进行加密保护机制。

6.3.1.4.3 完整性

车内通信应采用完整性保护机制。

6.3.1.4.4 可用性

车内通信应具备通信流量控制能力。

示例:当受到恶意软件感染或拒绝服务攻击而造成车内通信流量异常时,仍有能力提供可接受的通信。

6.3.1.4.5 访问可控性

车内通信应符合如下访问可控性要求：

- a) 将车内网络划分为不同的信息安全区域，每个信息安全区域之间宜进行网络隔离；
- b) 信息安全区域间采用边界访问控制机制对来访的报文进行控制。

示例：采用报文过滤机制、报文过载控制机制和用户访问权限控制机制等。

6.3.1.4.6 可核查性

车内通信应具备日志记录的能力。

示例：记录流量过载、高频率的收到异常报文等现象。

6.3.1.4.7 可预防性

车内通信应对异常报文具有感知能力；当感知到异常报文时，宜具有告警或其他安全响应的能力。

示例：接收到高频率的重放报文或被篡改过的报文等异常现象。

6.3.2 车外通信的保护要求

6.3.2.1 车外远距离通信的保护要求

6.3.2.1.1 真实性

车外远距离通信应符合如下真实性要求：

- a) 开启 3G、4G、5G 通信网络层的双向认证功能；
- b) 蜂窝移动通信网络层之上支持独立的双向认证机制。

6.3.2.1.2 保密性

车外远距离通信应符合如下保密性要求：

- a) 具备 3G、4G、5G 通信网络层的加密功能；
- b) 蜂窝移动通信网络层之上支持独立的加密机制，宜采用 TLS1.2 版本及以上的安全协议。

6.3.2.1.3 完整性

车外远距离通信应符合如下完整性要求：

- a) 具备 3G、4G、5G 通信网络层的完整性保护功能；
- b) 蜂窝移动通信网络层之上支持独立的完整性机制，宜采用 TLS1.2 版本及以上安全协议。

6.3.2.1.4 可用性

与外部通信的部件应支持防 DoS/DDoS 攻击。

6.3.2.1.5 访问可控性

车外远距离通信应具备对通信报文进行访问控制的能力。

示例：白名单访问控制、报文过滤、防通信流量过载机制等。

6.3.2.1.6 抗抵赖

车外远距离通信应符合如下抗抵赖要求：

- a) 确保蜂窝移动通信网络层通信 ID(如：国际移动用户识别码 IMSI、集成电路卡识别码 ICCID

等)的唯一性;

b) 蜂窝移动通信网络层之上支持独立的抗抵赖机制(如:使用证书机制等)。

6.3.2.1.7 可预防性

车外远距离通信应具备对通信报文的安全监控能力和攻击行为的感知能力;当受到信息安全攻击时,宜进行报文清洗、流量控制或阻止攻击行为的响应。

6.3.2.2 车外近距离通信保护要求

6.3.2.2.1 真实性

车外近距离通信应开启身份认证功能。

6.3.2.2.2 保密性

车外近距离通信应开启加密功能。

6.3.2.2.3 完整性

车外近距离通信应开启完整性保护功能。

6.3.2.2.4 可用性

与外部通信的部件应支持防 DoS/DDoS 攻击。

6.3.2.2.5 可核查性

车外近距离通信应具备记录近距离通信信息安全相关事件的能力;记录的内容宜包含来访用户 ID 和通信时间。

附录 A
(资料性)
信息安全威胁

A.1 车内系统信息安全威胁

A.1.1 软件系统的信息安全威胁示例

表 A.1 列举了软件系统可能面临的信息安全威胁。

表 A.1 软件系统的信息安全威胁

编号	威胁描述
1	用户通过越权方式访问软件系统,包含两个方面: a) 普通用户通过非正常渠道篡改和提升其权限,从而访问权限外的数据和文件; b) 利用系统访问机制设置不恰当的漏洞(如没有对用户做最小权限设置),访问不应访问的资源
2	用户利用用户身份认证不充分或默认账号密码未修改等问题非法访问车内软件系统
3	攻击者利用软件系统中存在不安全的远程访问或控制组件(如 Telnet、FTP、TFTP 以及其他不需要强认证和未加密传输的远程控制组件)远程非法访问车内系统
4	攻击者发现并利用软件系统中未移除或禁止功能业务中未用的组件和协议端口等隐藏的服务和端口攻击系统
5	攻击者通过操纵软件升级的确认机制,让软件系统拒绝正常的软件升级或让车辆在不恰当的时间和地点停车进行软件升级
6	攻击者通过重放合法的升级软件包让汽车反复升级软件以干扰车辆正常工作
7	车辆升级软件时没有进行来源合法性和软件包的完整性等可信环节的检查,导致非法软件安装到车辆中
8	车辆的软件系统没有足够完备的信息安全日志或其他事件记录系统,导致无法感知攻击和异常行为,给事后的信息安全事故调查、取证和追溯等带来困难
9	软件系统缺乏可信的启动机制,导致系统运行被篡改过的或不完整的软件
10	软件系统的访问认证机制缺乏防暴力破解措施,使攻击者可利用暴力方式直接破解访问的账号和密码
11	软件系统尤其是数据库对接收到的输入命令不校验格式的合法性,导致出现注入攻击
12	攻击者通过“后门”(如:组合键、鼠标特殊敲击、连接特定接口,使用特定客户端、使用特殊 URL、隐藏的访问账号、隐藏的远程访问通道等方式)非法进入车内软件系统
13	车辆软件系统缺乏预警与监控机制或预警与监控机制不充分,无法感知自身所面临的异常信息处理行为,导致用户或后台服务器无法及时采取应对措施

A.1.2 硬件的信息安全威胁示例

表 A.2 列举了电子电气硬件可能面临的信息安全威胁。

表 A.2 电子电气硬件的信息安全威胁

编号	威胁描述
1	芯片缺乏独立的信息安全存储空间或可信计算空间去存储密钥、用户认证的生物特征信息等安全重要参数,从而导致泄密。例如,通过 OS 内存泄密;在各种应用执行认证时,可直接访问安全重要参数,从而导致泄密
2	攻击者针对芯片的信息安全存储进行攻击以窃取安全重要参数。例如,实施侧信道攻击、故障注入攻击等物理攻击以及穷举暴力攻击和信息安全协议攻击等逻辑攻击方式
3	攻击基于芯片的软件系统可信启动机制,破坏软件启动前的可信环境和可信证明过程。例如,修改预存储的软件完整性校验值或伪造软件的远程证明凭证等
4	攻击者直接接入硬件调试接口。如 JTAG、串口或能访问硬件的管脚 PIN,对 ECU 和芯片进行非法调试
5	攻击者通过攻击物理设备或利用物理泄露进行攻击或对电子硬件实施物理注入攻击,包括入侵式攻击(如反向工程破解)、半入侵式注入攻击(如噪声注入、激光照射攻击等)和非入侵式的侧通道攻击(通过电磁波、时序等分析密钥等)

A.1.3 车内数据的信息安全威胁示例

表 A.3 列举了车内数据可能面临的信息安全威胁。

表 A.3 车内数据的信息安全威胁

编号	威胁描述
1	车内系统对安全重要参数的存储(如通信密钥、车辆数字证书私钥、车辆长期 ID 等)缺乏有效的保护措施,导致安全重要参数的信息泄露。例如,采用明文存储、未采用专门的隔离区进行存储、加密安全重要参数的密钥采用固定密钥或直接写死在代码中而导致加密密钥泄密问题
2	车内系统对存储的车内数据缺乏有效的访问权限控制,导致攻击者通过各类通信通道非法窃取和篡改数据
3	车内各类软件涉及安全重要参数因使用时保护不当而发生泄露。例如,缓存中存在加密密钥和认证凭证、信息安全日志或其他记录文件记录了密钥和长期 ID 等信息
4	车内系统的配置参数(如发动机配置参数、控制算法的建模参数和感知系统的配置参数等)缺乏有效的保护,导致攻击者通过修改这些配置参数操纵车辆
5	车辆共享同样的安全重要参数(如所有车辆使用同样的 root 口令或车辆软件对于外部输入数据检查及保护不足)导致代码注入攻击

A.1.4 车内通信的信息安全威胁示例

表 A.4 列举了车内通信可能面临的信息安全威胁。

表 A.4 车内通信的信息安全威胁

编号	威胁描述
1	由于车内网络未采用分区分域信息安全隔离方式,导致攻击者一旦攻破某个单元即可对整个车内系统发起跨越式攻击
2	车内网络连接缺乏对消息来源的真实性和完整性校验机制,导致攻击者一旦入侵了某个车内信息单元即可通过篡改消息和伪造消息操纵车辆
3	车内网络系统缺乏防 DDoS 或流控措施,发生某些信息单元被攻击者操纵或在功能故障后向车内总线发送大量的异常报文,导致车内通信系统拒绝服务
4	攻击者截取合法报文,导致不断地进行重复发送,进行重放攻击
5	通过 OBD 接口接入总线方式或植入恶意软件的方式,监听车总线的控制消息,破解不同运行状态的控制消息内容

A.2 车外通信的信息安全威胁

A.2.1 车外远距离通信的信息安全威胁示例

表 A.5 列举了车外远距离通信可能面临的信息安全威胁。

表 A.5 车外远距离通信的信息安全威胁

编号	威胁描述
1	对汽车实现通信欺骗。例如,伪造基站或者路基通信设施身份、向车辆发送假冒的 V2X 消息或者卫星导航信息;伪造车辆 ID、采用女巫攻击、伪造众多虚假车辆,影响车辆的正常行驶;伪造后端服务器身份、向汽车推送各种交互指令和伪造的软件升级包
2	利用通信通道对车辆通信实施 DoS/DDoS 攻击,造成车辆的信息处理功能中断。例如,发送各种通信协议的畸形报文、重放合法报文、大流量报文攻击等
3	通过架设无线干扰器来干扰 V2X 或卫星导航信号,造成车辆无法正常通信
4	车辆与车外系统之间的通信加密密钥被窃取或采用明文方式通信,导致通信内容存在泄露的风险
5	车辆与车外系统之间通信通道的完整性保护密钥被窃取或未采用完整性保护措施,导致通信内容被非法篡改
6	采用中间人攻击方式向车辆或车外系统发送伪造的服务拒绝响应消息,干扰正常通信
7	攻击者利用车的通信信道对车实施网络嗅探。例如,IP 端口扫描、ping 扫描、TCP syn 扫描等针对 IP 通信的嗅探
8	车辆和各类后端服务器之间的通信缺乏端到端的信息安全保护机制,使得攻击者利用中间薄弱环节实施攻击,包括窃听、伪造身份通信、篡改通信内容等
9	针对车辆的证书发放系统的攻击。例如,恶意注入伪造的证书撤销列表 CRL 等

A.2.2 车外近距离通信的信息安全威胁示例

表 A.6 列举了车外近距离通信可能面临的信息安全威胁。

表 A.6 车外近距离通信的信息安全威胁

编号	威胁描述
1	利用门禁的无线通信信道进行伪造门禁控制命令。例如,采取无线中继放大器进行中间人攻击方式,分别向车钥匙和门禁系统发生伪造信号,骗取正确的应答信号,从而打开门禁甚至启动引擎
2	通过无线通信信道破解车钥匙。例如,通过暴力破解方式,反复向门禁系统发送控制信息,或通过监听通信信道进行前向预测攻击、重放攻击、字典式攻击
3	伪造近距离通信报文。例如,伪造胎压管理系统 TPMS 的近距离通信消息,向相关 ECU 发送错误的胎压检测信息等
4	攻击者通过各类接触式的通信接口(如 OBD 接口、充电桩接口、USB 接口等)入侵车内系统,包括植入恶意软件、修改车内的关键控制系统的参数配置、窃取车内数据、非法访问文件、注入非法数据等行为
5	针对车内的无线局域通信(如蓝牙和 Wi-Fi)发起包括伪造 AP 和暴力破解方案的攻击,或利用无线局域网非法接入车载系统

参 考 文 献

- [1] ISO/IEC 21827:2008 Information technology—Security techniques—Systems Security Engineering—Capability Maturity Model
- [2] ISO/IEC 27033-1:2015 Information technology—Security techniques—Network security—Part 1: Overview and concepts
- [3] ISO/IEC 27039:2015 Information technology—Security techniques—Selection, deployment and operations of intrusion detection and prevention systems(IDPS)
-